

КИБЕРБЕЗОПАСНОСТЬ И ЗАЩИТА МЕДИЦИНСКИХ ДАННЫХ

Предварительная оценка соответствия MedConnect зарубежным стандартам и требованиям

Параметр	Значение
Проект	MedConnect (teleMed)
Получатель	Руководство проекта
Дата среза	22 июля 2026 года
Версия	1.0
Статус	Для внутреннего использования; не является сертификатом или юридическим заключением

Итоговый управленческий вывод

MedConnect имеет хорошую техническую основу — ролевую модель, проверки принадлежности данных, защищённую выдачу файлов, WebSocket-аутентификацию и базовые защитные заголовки API. Однако на дату оценки проект не может обоснованно заявлять полное соответствие или сертификацию по ISO 27001, ISO 27799, ISO 27701, HIPAA, GDPR, IEC 81001-5-1 либо OWASP ASVS. Текущий статус: частичная техническая готовность при существенных пробелах в управлении, аудите, защите конечных точек и доказательной базе.

Рекомендуемое решение: утвердить 180-дневную программу устранения разрывов и не использовать внешние формулировки «соответствует ISO/HIPAA/GDPR» до проведения формальной проверки применимости и независимого аудита.

1. Резюме для руководства

Цель работы — определить, какие зарубежные стандарты и режимы защиты медицинских данных релевантны MedConnect, сопоставить их с фактическим состоянием проекта и сформировать план выхода на доказуемое соответствие.

Короткий ответ на вопрос «проходит ли проект по стандартам?»

Пока нет — если под «проходит» понимать официально доказанное соответствие, аудит или сертификацию. По коду видны сильные отдельные контроли, но стандарты оценивают не только приложение: они требуют системы управления рисками, политик, договоров с поставщиками, журналов доступа, восстановления, реагирования на инциденты, защищённого жизненного цикла разработки и подтверждающих записей.

Ключевые выводы

- Наиболее релевантная целевая связка для международного рынка: ISO/IEC 27001:2022 + ISO 27799:2025 + ISO/IEC 27701:2025; для разработки — IEC 81001-5-1:2021, NIST SSDF и OWASP ASVS 5.0.
- GDPR обязателен при обслуживании лиц в ЕС либо мониторинге их поведения; HIPAA — при работе с американскими covered entities/business associates и ePHI. EHDS и NHS-требования зависят от рынка и интеграции.
- Наиболее срочные риски: медицинский текст в push-уведомлениях; JWT в localStorage; отсутствие полного журнала чтения/скачивания медицинских данных; критические и высокие уязвимости зависимостей; неподтверждённое шифрование хранения и резервных копий; риск устаревших локальных загрузок.
- Проекту не хватает доказательств управленческого соответствия: ISMS/PIMS, реестра активов и данных, риск-регистра, Statement of Applicability, DPIA, договоров DPA/BAA, проверок резервного восстановления, плана реагирования и независимого теста на проникновение.
- Заявление о соответствии допустимо только после закрытия критических разрывов и формирования доказательной базы; ISO-сертификация требует внешнего сертификационного аудита.

Приоритет решения

Горизонт	Результат	Решение руководства
0–30 дней	Снизить непосредственный риск утечки и компрометации	P0: push, зависимости, MFA, аудит, шифрование, legacy-файлы
30–90 дней	Закрыть ключевые технические и privacy-процессы	P1: сессии, SIEM, AV, backup/restore, права субъектов, поставщики
90–180 дней	Сформировать проверяемую систему управления	P2: ISMS/PIMS, DPIA, SoA, SSDLC, pentest, подготовка к ISO-аудиту

2. Область, методика и ограничения

2.1. Объект оценки

Оценивались репозиторий MedConnect, конфигурация Strapi/React/Node, механизмы аутентификации и авторизации, работа с медицинскими файлами и сообщениями, WebRTC/signaling, мобильные настройки Android, документация по production readiness, QA-артефакты, а также публично наблюдаемые production-контроли.

2.2. Методика

- Изучение официальных актуальных источников стандартов, регуляторов и отраслевых руководств.
- Статический обзор архитектуры и security-sensitive участков кода.
- Проверка заявленных эксплуатационных мер по документации и доступным публичным признакам.
- Сопоставление фактов с доменами управления, privacy, secure SDLC, доступом, аудитом, шифрованием, восстановлением и реагированием.
- Dependency snapshot: `npm audit --omit=dev` для frontend, server и signaling-server на дату среза.
- Классификация разрывов по срочности: P0, P1, P2; без искусственного числового балла зрелости.

2.3. Ограничения и границы уверенности

- Не предоставлялись доступы к админ-панели production, базе данных, объектному хранилищу, KMS, SIEM, резервным копиям, облачной панели и CI/CD.
- Не проверялись реальные договоры, DPA/ВАА, реестр субпроцессоров, кадровые процедуры, обучение и физическая безопасность.
- Не проводились pentest, DAST, проверка мобильного бинарника, криптографическая экспертиза и восстановление из резервной копии.
- Выводы о production ограничены доступными публичными ответами и репозиторием; отсутствие доказательства не всегда означает отсутствие контроля, но означает невозможность зачесть его для аудита.
- Локальное законодательство Республики Казахстан и отраслевые требования заказчика должны оцениваться отдельным юридическим треком.

Правовая оговорка

Документ является техническим gap-assessment. Он не заменяет юридическое заключение, официальную HIPAA/GDPR-оценку, клиническую safety case или сертификационный аудит.

3. Контекст системы и защищаемые данные

3.1. Краткая архитектура

Компонент	Назначение	Security relevance
React/Vite frontend	Веб-интерфейсы пациента, врача, администратора и поддержки	Хранение токена, XSS/CSP, privacy UX, file access
Strapi backend	API, RBAC, данные пользователей, приёмы, сообщения, документы, согласия	Главный policy enforcement point и источник audit events
Node signaling	WebRTC-сигналинг и комнаты консультаций	JWT, room authorization, логирование идентификаторов
PostgreSQL	Транзакционные и медицинские данные	TLS, at-rest encryption, backup, retention, access audit
S3/MinIO	Файлы и медицинские документы	Private bucket, proxy, SSE/KMS, legacy local uploads
Firebase Cloud Messaging	Push-уведомления	Передача preview/PII третьей стороне и lock-screen exposure
SMTP / платежи / TURN-STUN	Коммуникации, оплата, медиатрафик	Поставщики, DPA/BAA, секреты, data flows, логи

3.2. Категории данных

- Идентификационные и контактные данные пациентов и врачей.
- Сведения о записи, специальности, жалобах, консультациях и истории взаимодействий.
- Медицинские документы и файлы, сообщения пациента и врача, технические метаданные.
- Согласия, события администрирования, платёжные идентификаторы и статусы без хранения карточных реквизитов.
- Device/push-токены, IP-адреса, WebSocket room IDs и эксплуатационные логи.

Классификация

Для международной оценки следует исходить из повышенной чувствительности: health data по GDPR, ePHI при применимости HIPAA и health information в терминологии ISO 27799. Даже короткий preview сообщения может раскрывать диагноз, симптом или факт обращения.

3.3. Упрощённый поток данных

Пользователь → frontend/mobile → Strapi API → PostgreSQL и private object storage; сообщения и события → realtime/signaling; push-уведомление → Firebase → устройство; платёжные статусы → платёжный провайдер; почтовые события → SMTP. Каждый внешний переход требует отдельного договора, минимизации данных, правил местонахождения и документированной ответственности.

4. Зарубежные стандарты и режимы

Ниже приведён набор, который практически покрывает управление организацией, health-specific security, privacy, безопасную разработку и требования рынков. Ссылки [S1]–[S21] приведены в приложении.

4.1. Базовая международная связка

Стандарт	Актуальная редакция	Что проверяет	Роль для MedConnect
ISO/IEC 27001	2022 + Amd 1:2024	ISMS, риск-менеджмент, управление контролями	Базовая сертифицируемая система управления [S1–S2]
ISO 27799	2025, Edition 3	Применение security controls к health information, включая remote/virtual care	Отраслевой профиль для медицинской платформы [S3]
ISO/IEC 27701	2025, Edition 2	PIMS, роли controller/processor, privacy governance	Доказательная privacy-система [S4]
IEC 81001-5-1	2021	Secure lifecycle для health software	Требования к разработке, сопровождению и vulnerability handling [S5]

4.2. Регуляторные и отраслевые режимы

Режим	Когда применим	Ключевой акцент
HIPAA Security Rule	США: covered entity/business associate и ePHI	Administrative, physical, technical safeguards; risk analysis; BAA [S6–S10]
GDPR	ЕС: establishment, предложение услуг людям в ЕС или monitoring	Art. 9, 25, 32, 33, 35; законность, minimization, DPIA, breach [S11]
EHDS	Выход на рынок EU EHR/health data; поэтапное применение	Интероперабельность, права, secondary use, security; основное применение с 26.03.2027 [S12]
NHS DCB0129 / DSPT	Поставка health IT в NHS England	Clinical risk management и CAF-aligned assurance [S17–S18]
NIST CSF / SSDF / SP 800-63B	Добровольные практики и контрактные ожидания	Govern–Recover, secure SDLC, современная authentication policy [S13–S15]
OWASP ASVS 5.0	Проверяемая security baseline веб-приложения	Verification requirements; для MedConnect целесообразен минимум L2 [S16]

5. Применимость к MedConnect

Главный принцип

ISO — добровольная система управления и сертификация выбранного scope; HIPAA, GDPR, EHDS и NHS — режимы, применимость которых определяется юрисдикцией, ролью, рынком, договорами и фактическими потоками данных. Один и тот же код не может сам по себе «получить HIPAA» или «пройти GDPR».

5.1. Практическая логика применимости

Режим	Предварительная применимость	Что сделать
ISO 27001 / 27701	Рекомендуется почти всегда	Организация определяет scope, создаёт ISMS/PIMS и проходит сертификационный аудит.
ISO 27799	Высокая релевантность	Применять как health-specific профиль поверх ISO 27001/27002; версия 2025 прямо охватывает remote care.
IEC 81001-5-1	Высокая релевантность	Применять к жизненному циклу health software независимо от обязательности сертификации.
HIPAA	Условно	Нужна юридическая квалификация ролей и US data flows; при работе как BA — BAA и документированные safeguards.
GDPR	Условно, но экстерриториально	Проверить EU users, establishment, targeting и monitoring; определить controller/processor и правовые основания.
EHDS	Условно и поэтапно	Проводить market/product assessment при выходе на ЕС и интеграции с EHR ecosystem.
NHS	Только UK/NHS	DCB0129 safety case и DSPT/CAF assurance требуются по контексту поставки.

5.2. Medical device boundary

По доступным функциям MedConnect выглядит как telemedicine/health IT платформа для записи, связи, обмена документами и консультации, а не как программное медицинское изделие, принимающее диагностическое или терапевтическое решение. Если появятся AI/clinical decision support, автоматическая интерпретация, триаж или расчёт лечения, потребуются отдельная квалификация по медицинскому регулированию (например, EU MDR), а также анализ IEC 62304 и ISO 14971.

6. Общая матрица соответствия

Статус означает наличие проверяемой доказательной базы на дату среза, а не потенциальную возможность реализовать контроль.

Стандарт	Цель	Наличие	Статус	Ключевой разрыв
ISO/IEC 27001:2022	ISMS, риски, SoA, аудит, improvement	Есть отдельные технические контроли	Не подтверждено	Нет полного ISMS/risk register/SoA/internal audit
ISO 27799:2025	Health-specific protection	RBAC, ownership, file proxy, consent	Частично	Нет полного audit trail, supplier/operations evidence
ISO/IEC 27701:2025	PIMS и privacy governance	Privacy page, consent records	Не подтверждено	Нет DPIA, ROPA, rights workflow, supplier governance
IEC 81001-5-1:2021	Secure health software lifecycle	Code review evidence локально	Не подтверждено	Нет formal SSDLC, threat model, SBOM, vuln process
HIPAA Security Rule	Safeguards и risk analysis	Access controls и transport protections частично	Не готово к заявлению	Нет BAAs/evidence, MFA, full audit, DR testing
GDPR	Art. 5/9/25/32/33/35	Consent и базовая privacy notice	Не готово к заявлению	DPIA, lawfulness, rights, retention, processors не доказаны
EHDS 2025/327	EU health-data ecosystem	Базовая цифровая платформа	Не оценено/не готово	Нужны market scope, interoperability и conformity mapping
OWASP ASVS 5.0 L2	Application security verification	RBAC/IDOR controls сильные	Не пройдено	JWT storage, CSP, dependencies, upload/session gaps
NHS DCB0129/DSPT	Clinical safety и CAF assurance	Нет достаточной evidence base	Не готово	Нет clinical safety case и DSPT assessment

Вердикт

MedConnect нельзя позиционировать как «сертифицированный» или «полностью соответствующий». Корректная формулировка: «проект реализует ряд технических мер и проходит программу подготовки к соответствию; формальная оценка не завершена».

7. Сильные стороны текущей реализации

Следующие меры реально снижают риск и могут стать частью аудиторской доказательной базы после формализации тестов, владельцев и эксплуатационных процедур.

Контроль	Факт в проекте	Какой домен поддерживает
Ролевая модель	Роли patient/doctor/admin/manager и серверные проверки в server/src/index.ts.	ISO access control; HIPAA access management; ASVS authorization
Защита от IDOR	Policies проверяют participant/member/owner для appointment, conversation, medical document и связанных ресурсов.	Least privilege и object-level authorization
Private file delivery	S3-файлы выдаются через file proxy с auth/ownership/share checks; no-store, attachment, nosniff.	Confidentiality, controlled disclosure
API headers/CORS	HSTS/CORS/security headers настроены на backend; production CORS блокирует посторонний origin.	Transport/browser hardening
Consent records	Версионированные записи согласий и email confirmation.	Accountability foundation
Realtime security	WebSocket JWT authentication и проверки доступа к комнатам; signaling применяет room authorization.	Session/communications authorization
Uploads	Whitelist расширений/MIME и лимит 10 MB.	Базовая защита при загрузке
Mobile backup	Android allowBackup=false и data extraction rules.	Снижение риска копирования локальных данных
Payment/video minimization	Карточные реквизиты не сохраняются; видеосессии не записываются; WebRTC шифрует транспорт.	Data minimization и confidentiality
QA evidence	Зафиксированы 37 API RBAC/IDOR сценариев с ожидаемыми запретами доступа.	Повторяемая verification evidence

Важно

Наличие хорошего control design в коде должно быть дополнено доказательством работы в production: тестами, логами, change records, мониторингом, ответственными и периодическим review.

8. Критические и высокие риски — P0

ID	Разрыв	Наблюдение	Риск	Требуемое действие
P0-1	Медицинский текст в push	Message lifecycle отправляет первые 80 символов сообщения и имя отправителя в Firebase push. Текст может попасть на lock screen и к внешнему обработчику.	Высокий	Передавать только generic «Новое сообщение»; содержимое получать после auth. Пересмотреть BAA/DPA и covered services. [E10][S19–S21]
P0-2	JWT в localStorage	Zustand persist сохраняет token/user/auth state в localStorage. При XSS токен может быть похищен; frontend production не демонстрирует полный набор CSP/HSTS/frame/referrer/permissions headers.	Высокий	Web: HttpOnly Secure SameSite cookie + CSRF либо короткоживущий access token с rotation/revocation. Mobile: Keychain/Keystore. Добавить CSP и headers. [E11]
P0-3	Нет полного access audit	Не найден единый неизменяемый журнал чтения, просмотра, скачивания, экспорта и шаринга всех медицинских данных. В документации это лишь требование.	Критический	Ввести централизованный audit event schema, immutable/WORM retention, actor/object/action/result/purpose/IP/device/correlation ID и review. [E12]
P0-4	Уязвимые зависимости	Snapshot: frontend — 1 high; server — 45 (2 critical, 10 high, 28 moderate, 5 low); signaling — 1 low. Нужна triage применимости transitive findings.	Критический	Патчить/обновить, создать exceptions с owners/expiry, включить SCA release gate и регулярный SBOM. [E16]
P0-5	At-rest/backup encryption не доказано	DB TLS настроен, но нет доказательств TDE/disk encryption, MinIO SSE/KMS, шифрования backup и управления ключами.	Высокий	Подтвердить и принудительно включить encryption at rest; KMS/HSM, rotation, separation of duties, encrypted backup и restore evidence.
P0-6	Legacy local uploads	В публичных данных выявлены старые assets с provider=local наряду с новым aws-s3. Это не доказывает утечку меддокументов, но создаёт риск обхода private proxy.	Высокий	SQL-инвентаризация medical-document.file.provider; миграция в private bucket; удалить публичные копии, ротировать ссылки, проверить access logs.
P0-7	Нет MFA для привилегированных ролей	В коде не найден обязательный MFA для admin/doctor/support и управляемая ревокация активных сессий.	Высокий	Phishing-resistant MFA минимум для staff/admin; recovery process, session inventory, forced revocation, step-up для экспорта/настроек.

Критерий закрытия P0

Недостаточно внести кодовое изменение. Нужны production deployment record, тесты, скриншоты/логи контроля, владелец, дата review и подтверждение отсутствия PHI в push/legacy public storage.

9. Существенные технические разрывы — P1

ID	Область	Разрыв	Ремедиация
P1-1	Rate limiting	Простой in-memory IP limiter сбрасывается при рестарте и не координируется между инстансами.	Redis/distributed limiter; ключи account+IP/device; separate policies для login/reset/OTP/API.
P1-2	Password/auth policy	Min 8 + forced composition + bcrypt max 72 не соответствует текущему NIST single-factor baseline: min 15, support ≥64, blocklist, без обязательных composition rules.	При отсутствии MFA перейти на ≥15; breached-password blocklist; rate limiting; безопасный recovery. [S14]
P1-3	File validation	Проверяются declared MIME/extension, но не magic bytes; нет AV/sandbox/quarantine; office macros остаются риском.	Content sniffing, AV/CDR по модели угроз, quarantine, safe rename, scan status before download.
P1-4	Frontend hardening	Backend имеет HSTS/CSP/nosniff, а публичный frontend не демонстрирует сопоставимый набор заголовков.	CSP с nonce/hash, HSTS, Referrer-Policy, Permissions-Policy, frame-ancestors, SRI по необходимости.
P1-5	Monitoring/IR	Документация требует central logs/alerts, но operational evidence и incident playbooks не предоставлены.	SIEM, auth/data-access alerts, on-call, triage, containment, regulator/user notification templates.
P1-6	Backup/DR	Заявлены daily backup, PITR и monthly restore drill, но нет результатов восстановления и RPO/RTO.	Определить RPO/RTO, immutable/offline copy, restore test с протоколом, ownership и exception handling.
P1-7	PII в логах	Регистрация, signaling и платежные события могут логировать fullName/email/userName/room/payment identifiers.	Structured logging, data classification, redaction, access restriction, retention и DLP checks.
P1-8	TURN credentials	Документация допускает static TURN credential, хотя readiness рекомендует ephemeral credentials.	Ротация, time-limited TURN credentials, secret manager, abuse monitoring.

10. Privacy, поставщики и процессы — P1/P2

10.1. Privacy notice и права субъектов

Текущая privacy page перечисляет врачей, платёжного провайдера и государственные органы, но не полностью отражает Firebase/Google, SMTP, hosting, MinIO/object storage, TURN/STUN и возможные международные передачи. Указаны analytics/cookies без доказанного consent manager. Не найдены end-to-end процессы доступа, экспорта, исправления, удаления, ограничения, возражения и отзыва согласия. Terms упоминают удаление через три года после удаления аккаунта, но серверная автоматизация не подтверждена. [E14]

10.2. Поставщики и договоры

- Создать реестр processors/subprocessors: hosting, DB, MinIO/S3, SMTP, Firebase, Halyk, TURN/STUN, support/monitoring.
- Для каждого определить data categories, purpose, location/residency, transfer mechanism, retention, deletion, incident SLA, audit rights и security annex.
- При HIPAA применимости проверить BAA и использовать только covered products/configurations; сама HIPAA-готовность Google Cloud не делает приложение compliant. [S20]
- Проверить Firebase privacy/data-location особенности и исключить sensitive content из push payload. [S19][S21]

10.3. Управленческая система

Артефакт	Содержание	Аудиторское доказательство
ISMS/PIMS scope	Юрилица, продукты, environments, люди, данные, поставщики и исключения	Утверждённый scope statement
Asset/data inventory	Системы, владельцы, классификация, data flows, residency	Реестр активов и data-flow maps
Risk management	Методика, критерии, risk owners, treatment, acceptance	Risk register + treatment plan
Statement of Applicability	ISO 27001 Annex A controls и обоснование	SoA с evidence links
Privacy accountability	ROPA, DPIA, lawful basis, notices, rights, retention	PIMS pack и DPIA
Incident/breach	Roles, playbooks, legal triggers, exercises	IR plan, table-top records, notification templates
Audit/improvement	KPIs, internal audit, management review, CAPA	Протоколы review и corrective actions

11. Детальная оценка по ISO

11.1. ISO/IEC 27001:2022

ISO 27001 сертифицирует систему управления информационной безопасностью в определённом scope, а не репозиторий. Для MedConnect положительными входами являются RBAC, security policies в коде и QA. Не доказаны контекст/заинтересованные стороны, лидерство, риск-методика, risk treatment, SoA, цели, competence, documented information, internal audit, management review и continual improvement. Поэтому соответствие не подтверждено. [S1–S2]

11.2. ISO 27799:2025

Версия 2025 адаптирует controls ISO/IEC 27002:2022 для health information и учитывает EHR, remote/virtual care и health software. MedConnect попадает в предметную область. Сильны object authorization и controlled file delivery; основные gaps — access audit, supplier assurance, encryption evidence, incident/continuity, operational records и формальная классификация health information. Статус: частичное техническое соответствие, не conformity. [S3]

11.3. ISO/IEC 27701:2025

Edition 2 (2025) задаёт PIMS и ответственность PII controller/processor. Consent records — полезная база, но нет доказанного ROPA, DPIA, privacy risk treatment, rights workflow, retention/deletion execution, processor contracts и cross-border transfer governance. Статус: не подтверждено. [S4]

11.4. IEC 81001-5-1:2021

Стандарт охватывает security activities жизненного цикла health software: требования, architecture, implementation, verification, release, maintenance и vulnerability handling. В проекте не найден единый formal SSDLC с traceability, threat model, security requirements, SBOM, coordinated vulnerability disclosure, release criteria и post-market monitoring. Статус: не подтверждено. [S5]

Рекомендуемый certification scope

Начать со scope «разработка, эксплуатация и поддержка платформы MedConnect и инфраструктуры обработки медицинских данных», затем уточнить юридические лица, environments и исключения. Не исключать support, signaling, storage и ключевых поставщиков из data-flow mapping.

12. HIPAA, GDPR, EHDS и NHS

12.1. HIPAA

HIPAA применим не по факту наличия медицинских данных вообще, а по ролям и US health ecosystem. При применимости понадобятся documented risk analysis/risk management, workforce and access procedures, audit controls, integrity, person/entity authentication, transmission security, contingency plan, evaluations и BAAs. Текущая HIPAA Security Rule остаётся действующей; NHS NPRM усиливает будущие требования, но не должна выдаваться за действующее финальное правило. Reginfo указывает ожидаемую финализацию в июле 2027 года. [S6–S10]

HIPAA-статус

Частичные технические safeguards присутствуют, но overall compliance не подтверждён: неизвестны covered roles/BAAs, нет полного risk analysis pack, MFA, audit evidence, contingency test и vendor evidence.

12.2. GDPR

Health data — special category (Art. 9). Для MedConnect ключевы Art. 25 privacy by design/default, Art. 32 security (включая уместные encryption/pseudonymisation, resilience, restore и regular testing), Art. 33 уведомление надзорного органа обычно не позднее 72 часов и Art. 35 DPIA при вероятном high risk/large-scale special-category processing. Нужны также lawful basis, transparency, minimization, purpose limitation, retention, rights и processor governance. [S11]

GDPR-статус

Базовые consent/privacy элементы есть, но готовность к заявлению отсутствует до DPIA, определения ролей и правовых оснований, исправления notices, реализации прав, retention/deletion и договоров с processors.

12.3. EHDS и NHS

EHDS Regulation (EU) 2025/327 применяется поэтапно; основная дата начала применения — 26 марта 2027 года, дальнейшие обязательства вводятся по этапам до 2035 года. Для MedConnect нужна отдельная product/market mapping по EHR system obligations, interoperability, logging и secondary use. Для NHS England необходимы DCB0129 clinical risk management и CAF-aligned DSPT assurance. Сейчас доказательной базы для этих режимов нет. [S12][S17–S18]

13. Secure SDLC и application security

13.1. OWASP ASVS 5.0

ASVS 5.0 — подходящая проверяемая baseline для веб/API. С учётом медицинских данных целесообразно target не ниже Level 2 и повышать требования для admin/export/medical-document workflows. Сильные стороны — object-level authorization и file proxy. Не закрыты session storage, CSP, MFA, upload scanning, audit, dependency hygiene и security testing. [S16]

13.2. NIST CSF 2.0 и SSDF

Функция CSF	Статус	Причина
Govern	Частично	Нет утверждённой governance/risk/supplier/privacy системы
Identify	Частично	Нет полного asset/data inventory и risk register
Protect	Частично	RBAC/file proxy есть; MFA/session/encryption gaps
Detect	Слабо доказано	Нет подтверждённого SIEM и полного data-access audit
Respond	Не доказано	Нет tested playbooks и breach workflow
Recover	Не доказано	Backup requirements описаны, restore evidence нет

13.3. Минимальный SSDLC

- Security requirements и misuse/abuse cases для каждого релиза.
- Threat modeling для auth, medical files, chat/push, payments, WebRTC и admin workflows.
- SAST, SCA, secret scanning, IaC/container scanning, DAST/API tests и SBOM в CI/CD.
- Mandatory review для security-sensitive changes и release gate по severity/SLA.
- Vulnerability disclosure, intake/triage, CVE/vendor monitoring и emergency patch procedure.
- Независимый pentest до заявления о соответствии и после крупных архитектурных изменений.

14. Production snapshot и зависимости

14.1. Автоматизированный readiness check

Проверка	Результат на 22.07.2026	Интерпретация
Отсутствие tracked env	PASS	Секреты не выявлены как отслеживаемые env-файлы
Env examples	PASS	Примеры конфигурации присутствуют
Frontend dependency audit	FAIL	1 high finding
Server dependency audit	FAIL	45 findings: 2 critical / 10 high / 28 moderate / 5 low
Signaling dependency audit	PASS no gate	1 low finding; требуется обычная triage

14.2. Публично наблюдаемые признаки

- Backend CORS отклоняет посторонний origin; HSTS/security headers присутствуют на API.
- Frontend не демонстрирует сопоставимый полный набор security headers.
- В публичном наборе doctor-photo assets наблюдались 9 новых aws-s3 и 6 старых provider=local; newest local — 13.02.2026, newest S3 — 21.07.2026.
- Наблюдение provider=local — индикатор миграционного риска, а не доказательство публичности медицинских документов или факта утечки.
- x-powered-by раскрывает Express/Strapi — низкий риск, рекомендуется отключить как hardening.

Dependency caveat

npm audit сообщает package-level vulnerability chains. Каждая critical/high finding должна получить reachability/applicability analysis, но отсутствие немедленной эксплуатации не является основанием игнорировать её без документированного исключения.

15. Дорожная карта 0–30 дней (P0)

#	Работа	Владелец	Definition of Done	Срок
1	Убрать PHI/PII из push payload	Backend + mobile/web	Generic notification; no message/sender text; regression tests	7 дней
2	Инвентаризировать legacy local files	Backend + DBA + Infra	0 medical docs on public/local provider; migration log	7 дней
3	Закрыть critical/high dependencies	Engineering	Triage vxex findings; patched versions/exceptions; CI gate	14 дней
4	Включить MFA для staff	IAM/Product	MFA enforced for admin/doctor/support; recovery tested	21 день
5	Полный medical access audit	Backend + Security	Read/view/download/export/share/admin events в central immutable store	30 дней
6	Подтвердить encryption at rest	Infra/Security	DB/storage/backup encryption evidence; KMS rotation; key access review	30 дней
7	Защитить frontend headers	Frontend/Infra	CSP/HSTS/referrer/permissions/frame tests in production	14 дней
8	Incident readiness	Security/Legal/Ops	Named owners, severity matrix, breach decision tree, contact list	30 дней

Контрольные метрики P0

#	Критерий
1	0 push payloads с message preview, ФИО или медицинскими атрибутами.
2	100% medical-document objects используют private provider/policy path.
3	0 необработанных critical vulnerabilities; high — в SLA либо с утверждённым временным исключением.
4	100% privileged human accounts под MFA.
5	100% чтений/скачиваний/экспортов медицинских данных создают audit event.
6	Успешный проверяемый restore и документированный RPO/RTO.

16. Дорожная карта 30–180 дней

16.1. 30–90 дней — P1

Поток	Результат
Сессии	HttpOnly/secure strategy для web; refresh rotation, revocation, device sessions; secure mobile storage
Authentication	Distributed rate limiting; account/IP/device signals; NIST-aligned password + breached blocklist
Uploads	Magic-byte validation, AV/quarantine, scan state, macro policy, safe download
Detection	Central logs/SIEM; alerts на auth anomalies, bulk access/export, policy denies, malware
Continuity	PITR/immutable backup; monthly restore; RPO/RTO; incident/table-top exercise
Privacy	DPIA draft, ROPA, notices, cookie/analytics truth, rights/withdraw/delete/export workflow
Suppliers	DPA/BAA/security annex, residency, subprocessors, incident SLA, deletion evidence
Logging	PII redaction, retention schedule, access review и monitoring

16.2. 90–180 дней — P2

Программа	Результат
ISMS/PIMS	Scope, политики, поли, asset/data inventory, risk register, treatment plan, SoA, KPIs
Privacy accountability	Final DPIA/ROPA, lawful basis map, retention/deletion, data-transfer and processor controls
SSDLC	Threat models, requirements traceability, CI security stack, SBOM, vuln disclosure/patch SLAs
Assurance	ASVS L2 evidence pack, независимый pentest, remediation verification
Operations	Management review, internal audit, supplier reviews, incident and recovery exercises
Certification	Readiness audit; ISO 27001 + ISO 27701 certification plan; ISO 27799 control mapping
Clinical/product	DCB0129/EHDS/MDR boundary assessment только для целевого рынка и будущих clinical functions

17. Доказательства для формального аудита

Домен	Минимальный evidence pack
Governance	Scope, org chart, policies, risk method/register, SoA, objectives, management review
People	Screening where lawful, NDAs, role definitions, security/privacy training, joiner-mover-leaver records
Assets/data	Asset inventory, data classification, data flows, ROPA, retention schedule, disposal evidence
Access	IAM matrix, MFA evidence, periodic reviews, privileged access logs, session/revocation records
Application	Architecture, threat models, security requirements, code review, ASVS test results, pentest
Vulnerabilities	SCA/SAST/DAST, SBOM, scan trends, exceptions, remediation SLAs, disclosure process
Infrastructure	Network diagrams, hardening, encryption/KMS, secrets, patching, configs, environment separation
Audit/monitoring	Medical access audit events, SIEM rules, alert tickets, log retention/integrity/access reviews
Continuity	Backup config, immutability, restore reports, RPO/RTO, DR exercise and lessons learned
Incident	IR plan, table-tops, breach decision log, contacts, post-incident corrective actions
Privacy	DPIA, lawful basis, notices, consent records, rights tickets, deletion/export evidence
Suppliers	Inventory, due diligence, DPA/BAA, data locations, subprocessors, annual review, exit/deletion

Рекомендуемый независимый контроль

- Technical architecture and configuration review с production read-only evidence.
- ASVS-based web/API pentest, отдельные authorization/IDOR и medical file access cases.
- Mobile assessment storage/deeplinks/network/push; WebRTC/TURN abuse scenarios.
- Cloud/storage/IAM/KMS review и практический backup restore.
- ISO 27001/27701 readiness audit с ISO 27799 mapping.
- Юридический applicability assessment по Казахстану, GDPR/HIPAA/EHDS и договорной модели.

18. Итоговое заключение

Формальный вывод

На 22 июля 2026 года MedConnect не имеет достаточных оснований заявлять полное соответствие зарубежным стандартам безопасности медицинских систем или требованиям защиты медицинских данных. Архитектура содержит значимые положительные контроли, особенно в RBAC, object authorization и private file access. Однако критические разрывы в push privacy, session security, access auditing, dependency hygiene, encryption evidence, MFA и legacy storage, а также отсутствие ISMS/PIMS и полного operational evidence исключают положительный формальный verdict.

Рекомендуемая внешняя формулировка

«MedConnect применяет многоуровневые технические меры защиты и реализует программу подготовки к международным требованиям ISO 27001, ISO 27799 и ISO 27701. Формальная сертификация и оценка применимости HIPAA/GDPR находятся в отдельном контуре и не заявляются как завершённые».

Условия изменения verdict на положительный

- Закрыты PO и подтверждены production evidence.
- Созданы ISMS/PIMS scope, risk register, SoA, DPIA/ROPA и supplier agreements.
- Пройден независимый pentest/ASVS verification с подтверждением remediation.
- Проведены restore и incident exercises с протоколами.
- Юридически определены применимые режимы и роли controller/processor/BA.
- Для заявления «сертифицировано ISO» получен действующий сертификат аккредитованного органа на корректный score.

При выполнении дорожной карты проект имеет реалистичную основу для выхода на проверяемое соответствие: наиболее сложная часть — не переписывание платформы, а закрытие нескольких security gaps и построение постоянной системы управления и доказательств.

Приложение А. Техническая доказательная база

ID	Источник	Использование
E1	server/src/index.ts	Роли и серверные настройки доступа
E2	server/src/policies/*	Object/participant/member policies для sensitive resources
E3	server/src/api/file-proxy/controllers/file-proxy.ts	Private file authorization и response hardening
E4	server/config/middlewares.ts	HSTS, CORS и API security headers
E5	server/src/api/consent-record/*	Версионированные consent records
E6	server/src/utls/realtime.ts; signaling-server/server.js	JWT и room access checks
E7	Upload middleware/config	Extension/MIME whitelist и 10 MB limit
E8	frontend/android/app/src/main/AndroidManifest.xml	allowBackup=false
E9	QA_REPORT_SENIOR_FULL_2026-06-24.md	37 RBAC/IDOR API cases
E10	server/src/api/message/content-types/message/lifecycles.ts:68–104	Push preview первых 80 символов и sender data
E11	frontend/src/stores/authStore.js:24, 171	Persist auth state в localStorage
E12	PRODUCTION_READINESS.md:13–21	Backup/log/audit как требования, а не operational proof
E13	server/src/middlewares/rate-limit.ts	In-memory rate limiter
E14	frontend/src/pages/PrivacyPage.jsx; TermsPage.jsx	Privacy notice, retention statements и gaps
E15	DEPLOYMENT.md; production config	TURN и инфраструктурные ожидания
E16	package-lock.json + npm audit snapshot 22.07.2026	Dependency vulnerabilities
E17	scripts/production-readiness-check.mjs	Readiness automation и gate results

Примечание: номера строк отражают состояние репозитория на дату оценки и могут измениться после правок.

Приложение В. Официальные источники

- [S1] ISO/IEC 27001:2022. <https://www.iso.org/standard/27001> — ISMS requirements
- [S2] ISO/IEC 27001:2022/Amd 1:2024. <https://www.iso.org/standard/88435.html> — Climate action changes
- [S3] ISO 27799:2025. <https://www.iso.org/standard/84647.html> — Health information security controls, Edition 3
- [S4] ISO/IEC 27701:2025. <https://www.iso.org/standard/27701> — Privacy information management systems, Edition 2
- [S5] IEC 81001-5-1:2021. <https://www.iso.org/standard/76097.html> — Security lifecycle activities for health software
- [S6] NIST SP 800-66 Rev. 2. <https://csrc.nist.gov/pubs/sp/800/66/r2/final> — Implementing the HIPAA Security Rule
- [S7] HHS: HIPAA Security Rule. <https://www.hhs.gov/hipaa/for-professionals/security/laws-regulations/index.html> — Current rule overview
- [S8] HHS: Security Risk Analysis. <https://www.hhs.gov/hipaa/for-professionals/security/guidance/guidance-risk-analysis/index.html> — Risk analysis guidance
- [S9] HHS: HIPAA Security Rule NPRM. <https://www.hhs.gov/hipaa/for-professionals/security/hipaa-security-rule-nprm/factsheet/index.html> — Proposed strengthening; current rule remains in effect
- [S10] Reginfo: RIN 0945-AA22. <https://www.reginfo.gov/public/do/eAgendaViewRule?RIN=0945-AA22&pubId=202510> — Rulemaking schedule
- [S11] GDPR — Regulation (EU) 2016/679. <https://eur-lex.europa.eu/eli/reg/2016/679/oj> — Official consolidated legal source
- [S12] EHDS — Regulation (EU) 2025/327. <https://eur-lex.europa.eu/eli/reg/2025/327/oj> — European Health Data Space
- [S13] NIST Cybersecurity Framework 2.0. <https://www.nist.gov/cyberframework> — Govern, Identify, Protect, Detect, Respond, Recover
- [S14] NIST SP 800-63B-4. <https://pages.nist.gov/800-63-4/sp800-63b.html> — Authentication and authenticator management
- [S15] NIST SP 800-218 SSDF. <https://csrc.nist.gov/pubs/sp/800/218/final> — Secure Software Development Framework
- [S16] OWASP ASVS 5.0. <https://owasp.org/www-project-application-security-verification-standard/> — Application security verification
- [S17] NHS DCB0129. <https://digital.nhs.uk/data-and-information/information-standards/governance/latest-activity/standards-and-collections/dcb0129-clinical-risk-management-its-application-in-the-manufacture-of-health-it-systems/> — Clinical risk management for health IT manufacturers
- [S18] NHS CAF-aligned DSPT. <https://digital.nhs.uk/cyber-and-data-security/guidance-and-resources/caf-aligned-dspt-guidance/audit-guides/strengthening-assurance-independent-assessment-summary-of-guides/cyber-assessment-framework-caf-aligned-data-security-and-protection-toolkit-dspt> — Cyber and data security assurance
- [S19] Firebase Cloud Messaging encryption. <https://firebase.google.com/docs/cloud-messaging/encryption> — Recommendation for end-to-end protection of sensitive messages
- [S20] Google Cloud HIPAA compliance. <https://cloud.google.com/security/compliance/hipaa-compliance> — BAA and covered products context
- [S21] Firebase privacy and security. <https://firebase.google.com/support/privacy/> — Data processing and location information

Принцип актуальности

Перед сертификацией или юридическим заключением необходимо повторно проверить редакции стандартов, даты применения регуляторных актов, официальные guidance и договорные условия поставщиков. Этот отчёт фиксирует состояние на 22 июля 2026 года.

Приложение С. Термины

Термин	Значение
ASVS	Application Security Verification Standard OWASP
BAA	Business Associate Agreement в контексте HIPAA
DPA	Data Processing Agreement
DPIA	Data Protection Impact Assessment
ePHI	Electronic Protected Health Information
ISMS	Information Security Management System
PIMS	Privacy Information Management System
ROPA	Record of Processing Activities
RPO / RTO	Recovery Point Objective / Recovery Time Objective
SBOM	Software Bill of Materials
SCA / SAST / DAST	Анализ зависимостей / статический / динамический анализ безопасности
SIEM	Централизованный сбор и корреляция security events
SoA	Statement of Applicability по ISO/IEC 27001
SSDLC	Secure Software Development Life Cycle
WORM	Write Once Read Many — неизменяемое хранение журналов

Конец отчёта

Документ подготовлен как предварительная техническая оценка для принятия управленческих решений. Следующий формальный шаг — назначить владельца программы соответствия, подтвердить применимые рынки и запустить PO remediation с еженедельным контролем evidence.